

Política de Controle de Acessos

Diretrizes para concessão, alteração, revisão e revogação de acessos administrativos, técnicos e de usuários.

Código	NRX-GOV-ACC-001	Versão	1.0
Responsável	Jhonatan Gasperi de Oliveira	Vigência	01 de julho de 2026
Classificação	Uso controlado	Próxima revisão	01 de julho de 2027

VIGENTE

Documento aprovado para uso interno e apresentação como evidência institucional, sujeito às revisões e controles descritos.

1. Objetivo

Estabelecer controles mínimos para que o acesso aos sistemas, dados e ambientes da NeuroNex AI seja individual, necessário, rastreável e compatível com as responsabilidades de cada pessoa ou serviço técnico.

2. Escopo

Aplica-se ao GitHub, Supabase, Vercel, Cloudflare/R2, Asaas, serviços Google, provedores de IA, ferramentas de suporte e demais sistemas que processem código, secrets, informações administrativas, financeiras, pessoais ou clínicas.

3. Princípios obrigatórios

- Privilegio mínimo: conceder somente o menor conjunto de permissões necessário para a atividade.
- Necessidade de saber: dados sensíveis devem ser acessíveis somente quando indispensáveis à finalidade autorizada.
- Identidade individual: contas compartilhadas são proibidas; cada acesso deve possuir responsável identificável.
- MFA: contas administrativas devem utilizar autenticação multifator sempre que o provedor disponibilizar o recurso.
- Separação de ambientes: acessos de desenvolvimento, homologação e produção devem ser segregados por projeto, papel e secret.
- Rastreabilidade: concessões, alterações, exceções e revogações devem gerar registro verificável.
- Bloqueio por padrão: na dúvida, o acesso deve permanecer negado até aprovação expressa.

4. Papéis e responsabilidades

Papel	Responsabilidade
Responsável institucional	Aprovar acessos, revisar permissões, manter evidências, decidir exceções e ordenar revogações.
Usuário autorizado	Proteger credenciais, usar MFA, não compartilhar contas e comunicar suspeitas imediatamente.
Conta técnica / serviço	Usar credencial própria, escopo mínimo, armazenamento server-side e rotação controlada.



Papel	Responsabilidade
Terceiro autorizado	Receber acesso temporário, limitado, nominal, contratualmente vinculado e sujeito a revisão após a tarefa.

5. Ciclo de vida do acesso

- Solicitação: registrar sistema, pessoa, papel, finalidade, prazo, ambiente e aprovador.
- Avaliação: verificar necessidade, risco, conflitos de função e possibilidade de acesso mais restrito.
- Concessão: criar conta individual, habilitar MFA, aplicar o menor papel possível e registrar evidência.
- Mudança: reavaliar imediatamente o acesso quando houver alteração de função, projeto ou escopo.
- Revisão: revisar acessos administrativos mensalmente e acessos não privilegiados, no mínimo, trimestralmente.
- Revogação: remover acessos sem necessidade, após término de contrato, desligamento, incidente ou solicitação do responsável.

6. Acesso à produção

- O acesso administrativo à produção é restrito ao responsável institucional, salvo autorização nominal e registrada.
- Mudanças críticas devem ocorrer por Pull Request, checks automatizados e registro de mudança, sempre que tecnicamente aplicável.
- Acesso direto ao banco, secrets ou dados sensíveis não deve ser utilizado como rotina operacional.
- Ações emergenciais devem ser justificadas, registradas e revisadas após a estabilização.

7. Dados clínicos e financeiros

O responsável técnico ou administrativo não deve acessar conteúdo clínico ou financeiro individual por conveniência. Acesso excepcional para suporte, investigação ou obrigação legal exige finalidade definida, minimização, registro, confidencialidade e, quando possível, uso de dados sanitizados.

8. Acessos de terceiros e contas técnicas

- Acesso de terceiros deve possuir prazo, escopo, responsável interno e evidência de encerramento.
- Tokens de integração e service roles não podem ser usados no navegador ou inseridos em código público.
- Integrações automatizadas devem ser inventariadas, revisadas e revogadas quando não utilizadas.

9. Evidências e registros

- Lista de membros e papéis com identificadores mascarados.
- Evidências de MFA habilitado e de proteção da branch principal.
- Registro mensal de revisão de acessos e decisões de manter, reduzir ou revogar.
- Registro de mudanças e exceções, sem incluir passwords, tokens ou chaves.

10. Exceções e não conformidades

Qualquer exceção deve ser temporária, documentada, aprovada pelo responsável institucional e acompanhada de controle compensatório. Acesso indevido, compartilhamento de conta ou ausência injustificada de MFA pode resultar em revogação imediata e abertura de incidente.



11. Revisão da política

Esta política deve ser revisada anualmente ou antes, quando houver incidente relevante, alteração material da arquitetura, contratação de equipe ou mudança de fornecedor crítico.

Aprovação

Aprovo este documento e determino sua aplicação a partir da data de vigência indicada.

Jhonatan Gasperi de Oliveira

Responsável e aprovador institucional

Assinatura digital: _____ Data: 01/07/2026